13.1.1 SSL/TLS certificates

Server authentication is guaranteed by the presence of a valid SSL or TLS certificate issued by a trusted *certificate authority* (CA). A list of all trusted CAs is built into your operating system or device, and clients such as web browsers use this list to verify the certificate issuer. The certificate issuer is responsible for ensuring the person who requests the certificate has control over the domain they are requesting the certificate for. This can be achieved in a number of ways, depending on the type of certificate being requested. The most common type of certificate is the *domain validation* (DV) certificate, which is used solely to validate who has control over the domain. Domain control can be verified by the addition of a specific DNS record or by using software on the server where the domain's IP address is assigned to request the certificate. These days, it is relatively easy to obtain DV certificates at no cost. More and more hosting companies offer them, or you can get them directly from an organization, such as Let's Encrypt (https://letsencrypt.org/).

NOTE SSL, or Secure Sockets Layer, was the original protocol used for encrypting HTTP messages. Some time ago, it was deprecated in favor of the newer Transport Layer Security (TLS) protocol, which is what is used these days. The term *SSL* is still used to refer to authentication certificates, although SSL itself is no longer used anywhere.

Other types of TLS certificate are available, known as *organization validation* (OV) and *extended validation* (EV). They validate your business and, in the case of EV certification, its ownership. If you use Cloudflare (https://www.cloudflare.com/) as a reverse proxy, they offer OV certificates for free, although the organization they authenticate is their own. Cloudflare encrypts traffic between the user and its services. You have to take extra steps to encrypt traffic between the origin server (where you host your site) and Cloudflare. EV certificates are usually the most expensive. If an EV was used, browsers used to display details of the business that owned the domain in the address bar (a so-called *EV UI*), but that is no longer the case (http://mng.bz/gRYv). The value proposition of an EV over that of a DV certificate centers around degrees of *trust* and identity assurance, although whether that is something a site visitor even understands is debatable (http://mng.bz/epRV).

When you visit a site over a secure connection that has a valid certificate of any kind, the browser displays a small padlock at the beginning of the address, shown in figure 13.1. The appearance of the padlock differs from browser to browser, but each padlock confirms the connection is secure and the certificate is valid. If you click the padlock, you can see further details of the certificate, such as the domain it validates, its expiry date, and who the issuer is.